W15D1

Null Session e ARP Poisoning

Emma Rullo

Sommario

Sono stati descritti la Null Session (connessione anonima a sistemi Windows via SMB/NetBIOS) e l'ARP Poisoning (avvelenamento della cache ARP per un attacco Man-in-the-Middle su rete locale), descrivendone per ciascuno il funzionamento, i sistemi vulnerabili e le contromisure.

Nella Pratica 1, tramite Ettercap è stato eseguito un ARP Poisoning ponendosi tra un host vittima e il router, verificando l'avvelenamento della cache ARP prima e dopo l'attacco, analizzando il traffico con Wireshark e intercettando credenziali HTTP in chiaro. Nella Pratica 2 è stata sfruttata la Null Session su una macchina Metasploitable per enumerare il sistema con enum4linux e smbclient e leggere il file /etc/passwd.

Prima parte – Quesiti teorici

1. Che cosa si intende per Null Session

Una Null Session (sessione nulla) è una connessione anonima — stabilita cioè senza fornire username e password — verso la share amministrativa nascosta IPC$ (Inter-Process Communication) di un sistema Windows, attraverso i protocolli SMB e NetBIOS. Nata come meccanismo legittimo per la comunicazione tra processi e servizi di sistemi diversi, può essere usata sfruttando la connessione anonima a IPC$, così che un attaccante è in grado di enumerare informazioni sensibili dell'host, tra cui l'elenco di utenti e gruppi, i SID, le share condivise, le policy di password e di lockout e i servizi attivi. Queste informazioni costituiscono una preziosa fase di ricognizione in vista di attacchi successivi.

2. Sistemi vulnerabili a Null Session e se sono ancora in commercio

Sono storicamente vulnerabili i sistemi Windows che espongono SMBv1 / NetBIOS over TCP/IP sulle porte 139 e 445 con il parametro RestrictAnonymous non impostato, in particolare nelle configurazioni di default di:

- Windows NT 4.0
- Windows 2000
- Windows XP
- Windows Server 2003

Questi sistemi non sono più in commercio né supportati: sono tutti End-of-Life (Windows XP dal 2014, Server 2003 dal 2015). A partire da Windows Vista / Server 2008 il parametro RestrictAnonymous è attivo per impostazione predefinita e la Null Session verso IPC$ è bloccata; inoltre SMBv1 è deprecato e disabilitato di default da Windows 10 / Server 2016. Di conseguenza, oggi la vulnerabilità si riscontra quasi esclusivamente su sistemi legacy non aggiornati o su configurazioni errate, non sui prodotti attualmente in vendita.

3. Come mitigare o risolvere la vulnerabilità Null Session

- Impostare le chiavi di registro RestrictAnonymous = 1 e RestrictAnonymousSAM = 1 e, nelle Group Policy, abilitare "Network access: Do not allow anonymous enumeration of SAM accounts and shares".
- Disabilitare il protocollo SMBv1, obsoleto e insicuro.
- Disabilitare NetBIOS over TCP/IP.
- Bloccare le porte 135–139 e 445 sul perimetro tramite firewall e segmentare opportunamente la rete; gestire con attenzione i permessi sulle share.
- Dismettere o aggiornare i sistemi operativi non più supportati, sostituendoli con versioni mantenute.

4. Come funziona l'ARP Poisoning

Il protocollo ARP (Address Resolution Protocol) risolve un indirizzo IP nel corrispondente indirizzo MAC all'interno di una rete locale. ARP è però privo di stato e di autenticazione: un host accetta e memorizza nella propria cache ARP anche le risposte (ARP reply) che non ha mai richiesto. L'attaccante sfrutta questa debolezza inviando ARP reply falsificate che associano il proprio indirizzo MAC agli indirizzi IP di due vittime, tipicamente l'host bersaglio e il gateway. Entrambi aggiornano la propria cache ARP e iniziano a inviare verso l'attaccante il traffico destinato all'altro: l'attaccante si colloca così "in mezzo" alle comunicazioni (Man-in-the-Middle) e può leggere, intercettare, modificare o bloccare tutto il traffico non cifrato che transita.

5. Sistemi vulnerabili a ARP Poisoning

L'ARP Poisoning sfrutta una debolezza intrinseca del protocollo ARP (IPv4) e non di uno specifico sistema operativo: sono quindi potenzialmente vulnerabili tutti i dispositivi che comunicano via IPv4/ARP sulla stessa LAN Ethernet o Wi-Fi — Windows, Linux, macOS, stampanti di rete, dispositivi IoT, smartphone e così via. L'equivalente in ambito IPv6, chiamato NDP spoofing, colpisce in modo analogo i dispositivi che usano IPv6. In pratica, qualsiasi rete locale priva di contromisure specifiche è esposta.

6. Come mitigare, rilevare o annullare l'ARP Poisoning

Mitigazione: configurare voci ARP statiche per gli host critici (ad esempio il gateway); sugli switch gestiti (layer 3) abilitare Dynamic ARP Inspection (DAI) insieme a DHCP Snooping, Port Security e segmentazione in VLAN/sottoreti; adottare protocolli sicuri e cifratura end-to-end (HTTPS/TLS, VPN, SSH) affinché, anche in caso di intercettazione, i dati restino illeggibili.

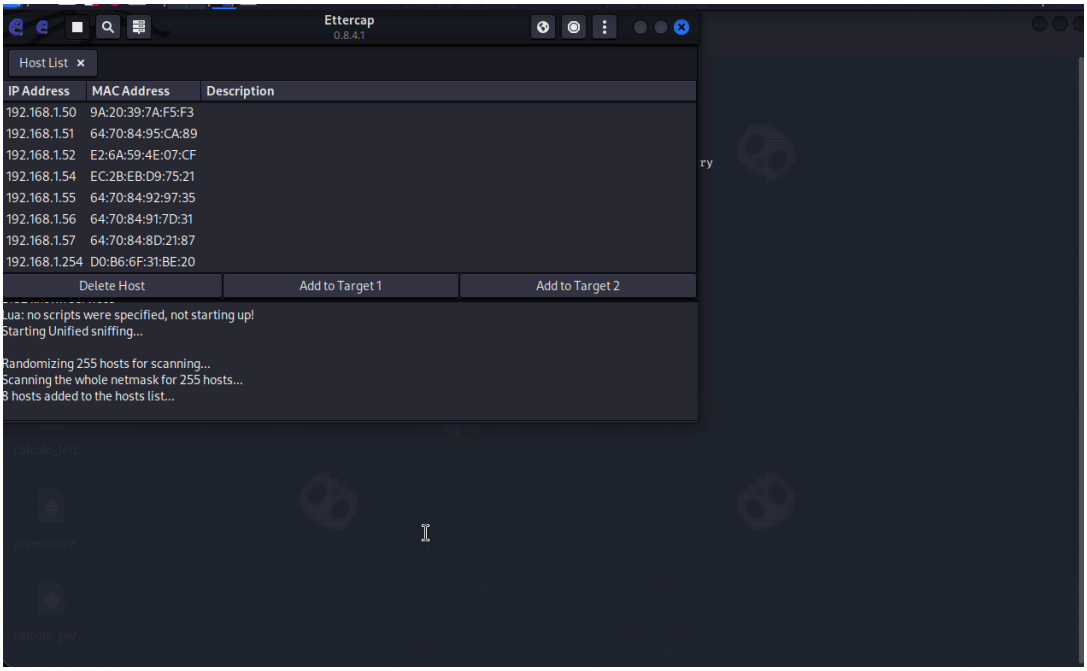
Rilevazione: impiegare strumenti come arpwatch, XArp o sistemi IDS/IPS (ad esempio Snort) che segnalano cambi sospetti nelle associazioni IP-MAC o la presenza di ARP reply anomale, con un monitoraggio costante della rete.

Annullamento: ipristinare la corretta associazione IP-MAC (impostandola come voce statica) e svuotare o correggere la cache ARP degli host colpiti, così da riportare il traffico sul percorso legittimo.

Pratica 1 – ARP Poisoning con Ettercap

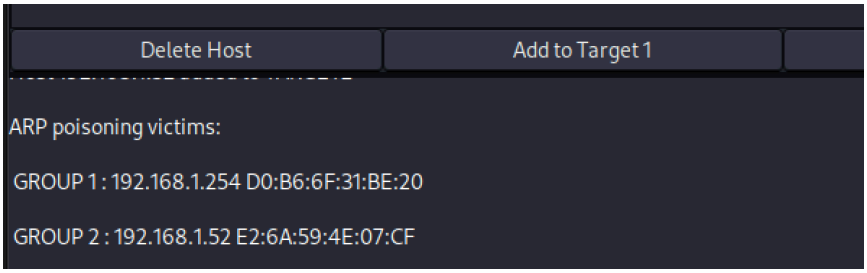
Ettercap è uno strumento di analisi di rete e di attacco Man-in-the-Middle. Qui è stato utilizzato per eseguire un ARP Poisoning, posizionandosi tra l'host vittima (192.168.1.52) e il router/gateway del provider (192.168.1.254), al fine di intercettare il traffico non cifrato che transita tra i due. La macchina attaccante è una VM Kali (192.168.1.59).

1. **Scansione della rete**. Da Ettercap, dopo aver selezionato l'interfaccia eth0 e avviato lo sniffing, con Hosts → Scan for hosts sono stati individuati i dispositivi della rete e si apre la Host List.



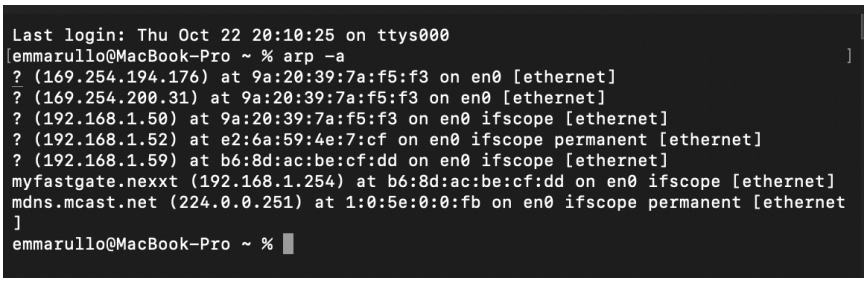
Host List: i dispositivi rilevati sulla rete, tra cui il router (192.168.1.254) e la vittima (192.168.1.52).

2. **Selezione dei target e avvio dell'attacco**. Router come Target 1 e vittima come Target 2, quindi dal menu MITM è stato avviato l'ARP poisoning con l'opzione "Sniff remote connections".



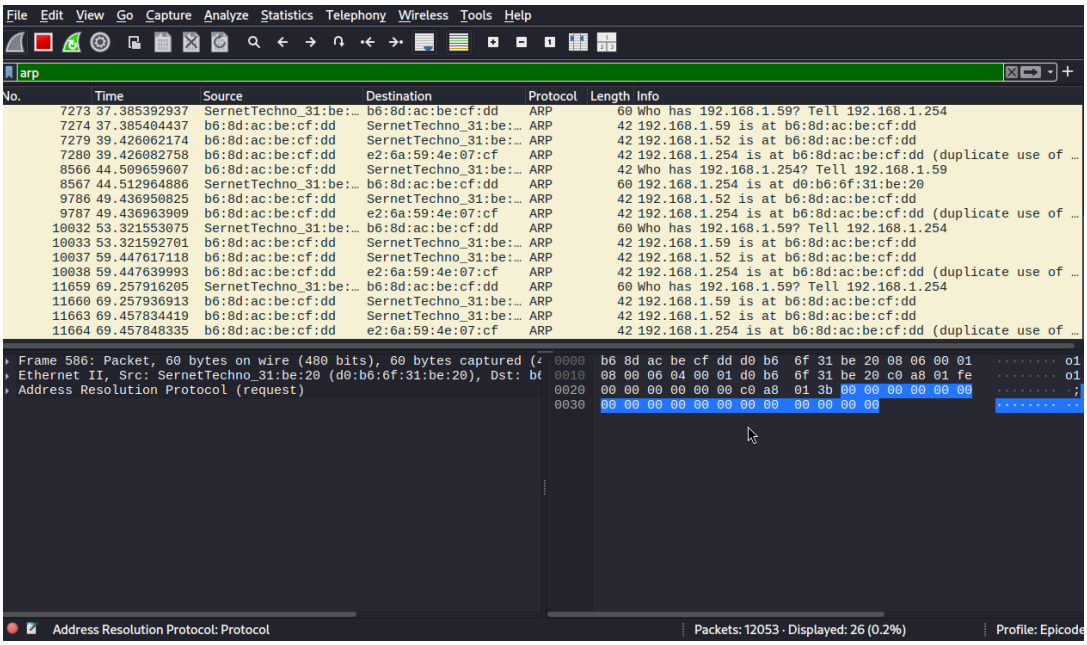
Avvio dell'attacco: Ettercap conferma le vittime dell'ARP poisoning (GROUP 1 = gateway, GROUP 2 = host vittima).

3. **Verifica dell'avvelenamento**. Eseguendo arp -a sulla vittima, l'indirizzo IP del gateway 192.168.1.254 risulta associato al MAC della macchina Kali (b6:8d:ac:be:cf:dd) anziché al MAC reale del router: la cache ARP è stata avvelenata.



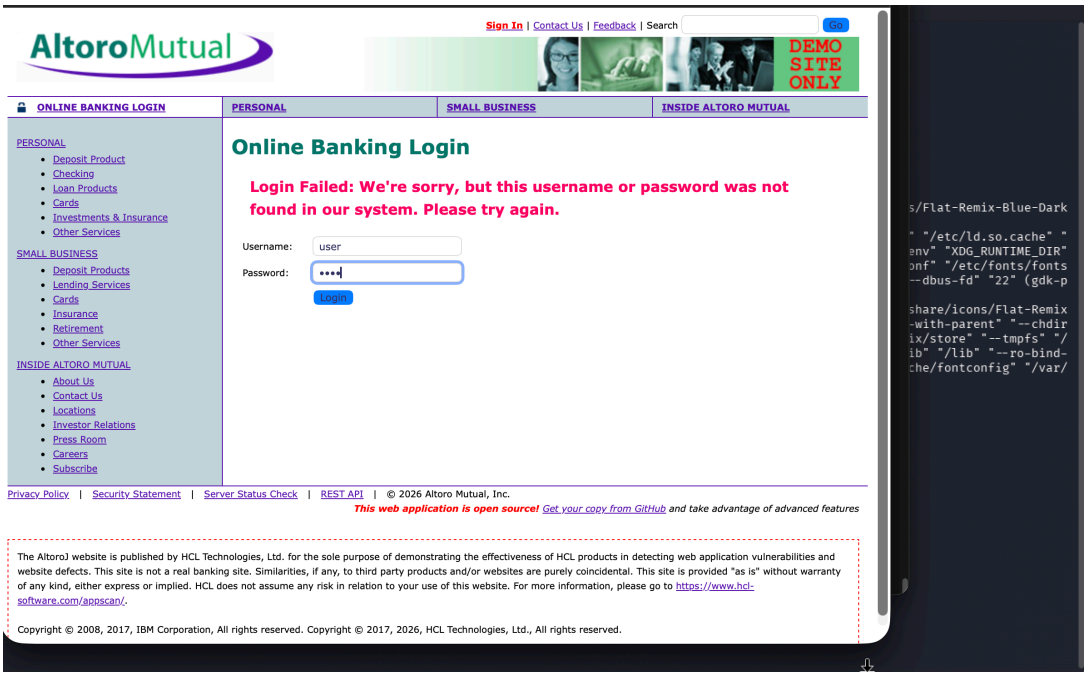
Cache ARP della vittima dopo l'attacco: il gateway 192.168.1.254 punta ora al MAC di Kali.

4. **Analisi del traffico con Wireshark**. Applicando il filtro arp si osservano le ARP reply falsificate ripetute ("192.168.1.254 is at b6:8d:ac:be:cf:dd"); Wireshark stesso segnala l'anomalia con l'avviso "duplicate use of", firma tipica dell'ARP poisoning.



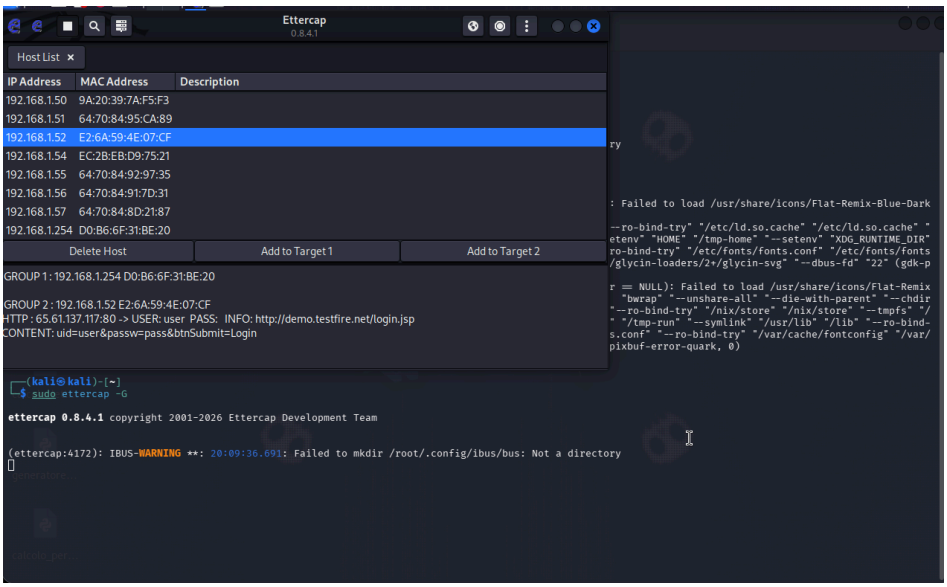
Wireshark (filtro arp): le reply falsificate periodiche con l'avviso di "duplicate use".

5. **Dimostrazione MITM su traffico HTTP**. Con l'attacco attivo, dalla vittima è stato effettuato il login su una pagina in HTTP (sito di test Altoro Mutual).



Login su una pagina HTTP non cifrata effettuato dall'host vittima.

6. **Cattura delle credenziali**. Poiché il traffico è in HTTP non cifrato, Ettercap intercetta e mostra in chiaro i dati inviati: la riga del log riporta USER e il CONTENT con uid e passw trasmessi nella POST.

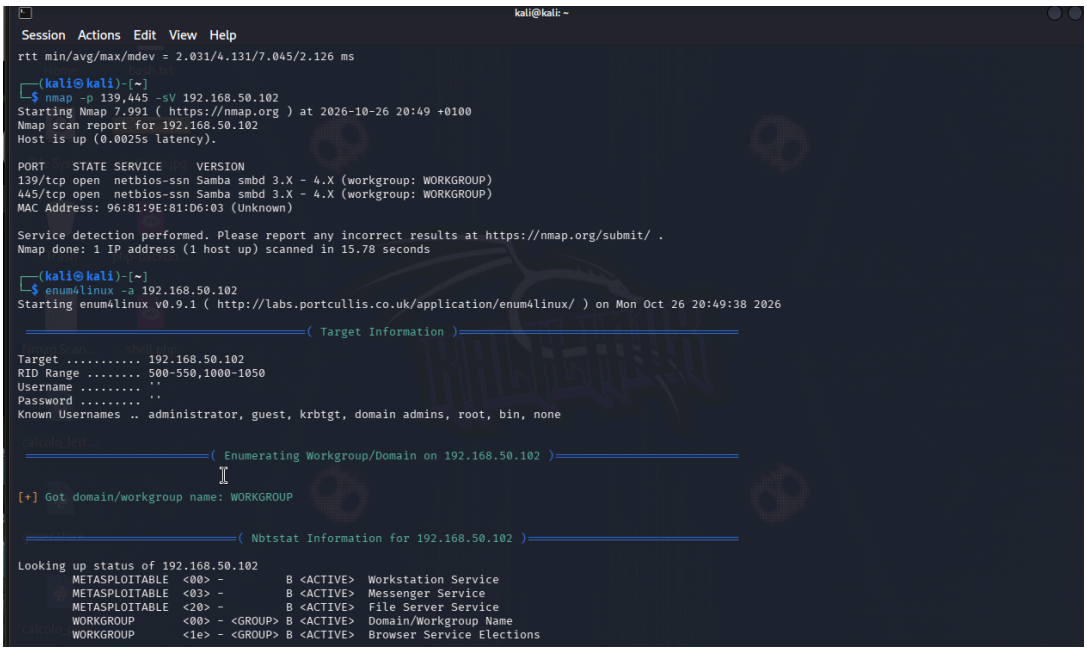


Log di Ettercap: credenziali HTTP intercettate in chiaro (uid=user, passw=pass).

Pratica 2 – Null Session su Metasploitable

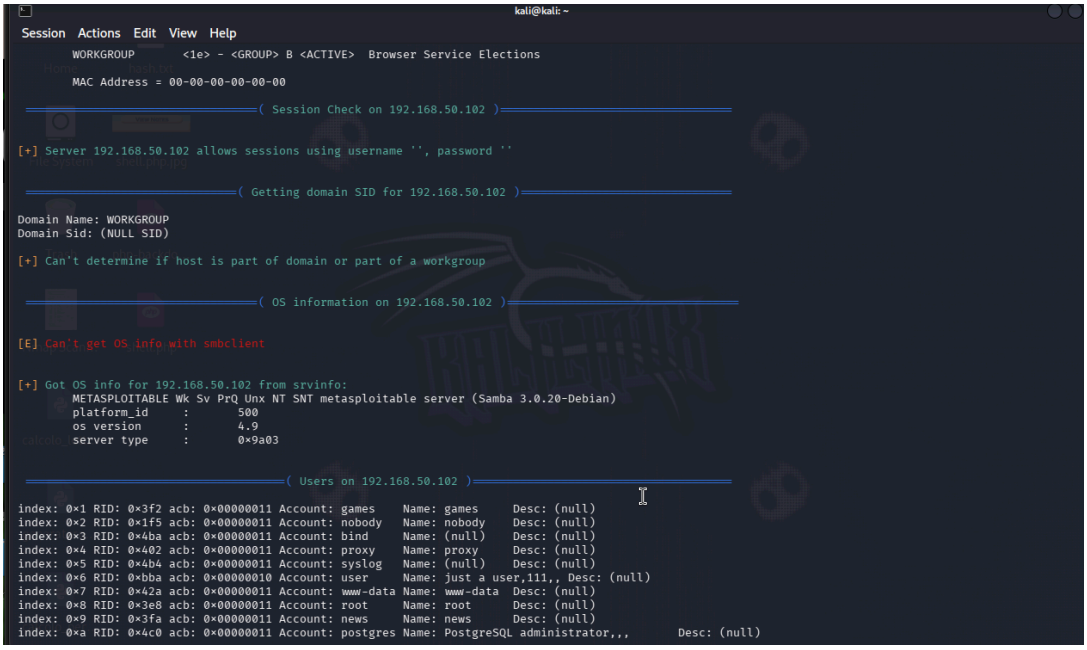
È stata dimostrata la vulnerabilità Null Session su una macchina Metasploitable (192.168.50.102), che espone un server Samba configurato in modo da permettere l'accesso anonimo, con l'obiettivo di enumerare il sistema senza credenziali e arrivare a leggere il file /etc/passwd. La macchina attaccante è Kali (192.168.50.100).

1. **Ricognizione del servizio SMB**. Con nmap si verificano le porte 139 e 445: risultano aperte ed esposte da Samba 3.0.20, versione vulnerabile.



nmap: porte 139/445 aperte, servizio Samba (smbd) sulla Metasploitable.

2. **Enumerazione con enum4linux**. Lo strumento conferma che il server "allows sessions using username '', password '' " (null session permessa) e ricava utenti, gruppi, informazioni sul sistema (Samba 3.0.20-Debian) e la password policy, il tutto senza alcuna credenziale.



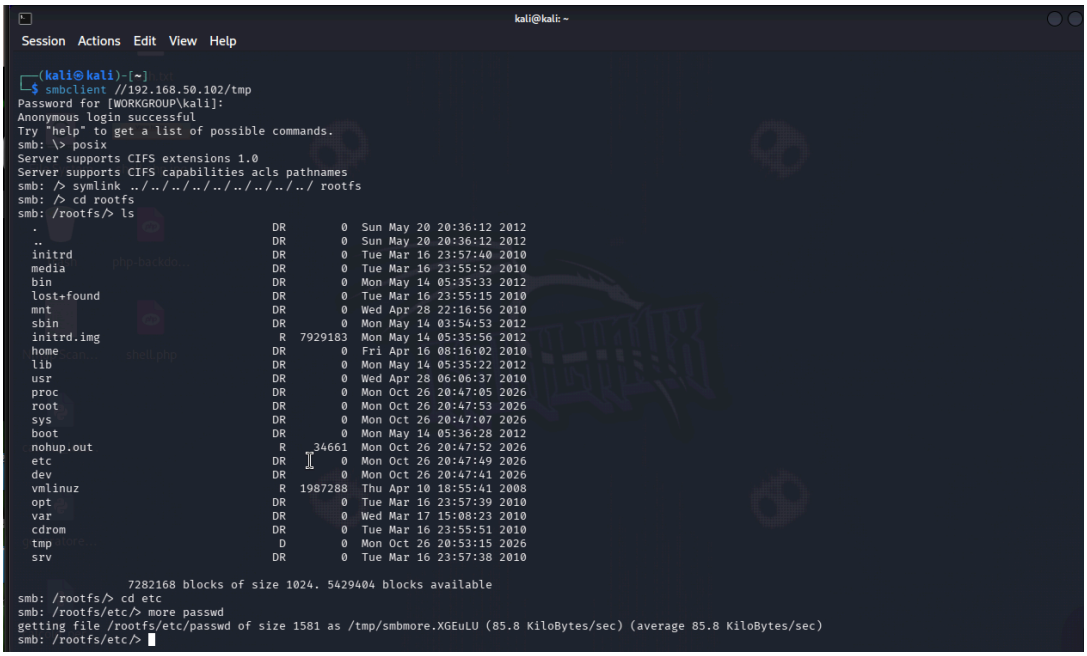
enum4linux: la sessione anonima è permessa; vengono enumerati OS e utenti del sistema.

3. **Elenco delle share in null session**. Con smbclient -L, premendo Invio alla richiesta di password (nessuna password), si ottiene "Anonymous login successful" e la lista delle share condivise (print$, tmp, opt, IPC$, ADMIN$).



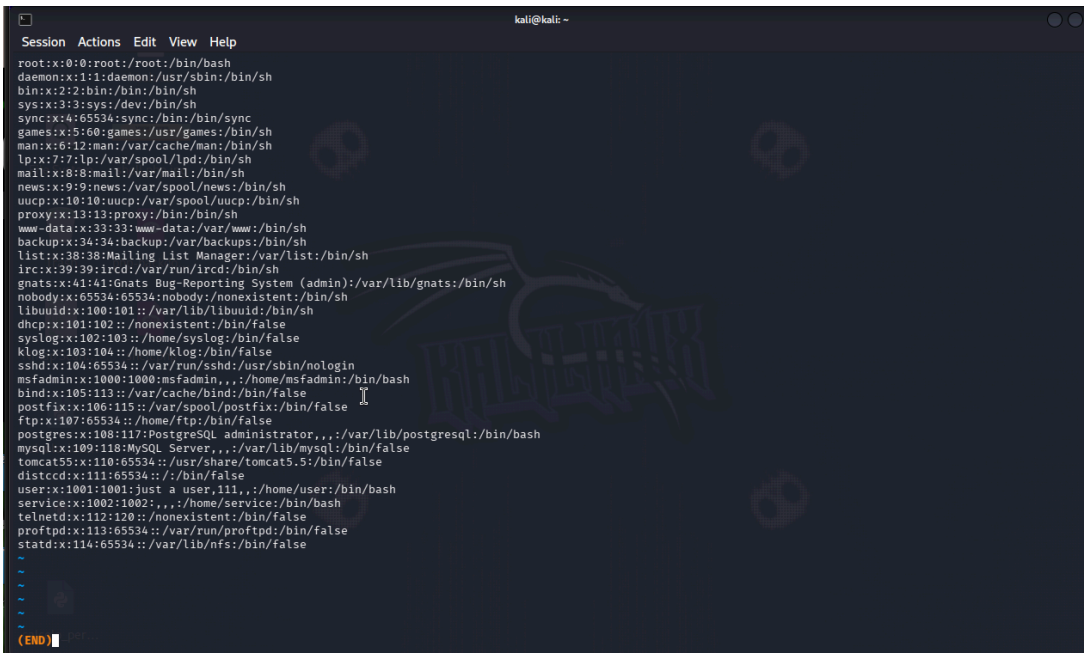
smbclient -L: login anonimo riuscito ed elenco delle share condivise.

4. **Accesso alla share tmp e traversal verso la root**. Connettendosi alla share tmp in sessione anonima, si attiva la modalità posix e si crea un symlink che, risalendo le directory, punta alla radice del filesystem; con cd rootfs e ls si ottiene l'intera root della Metasploitable (bin, etc, home, root, var…).



Symlink traversal: dalla share tmp si raggiunge e si elenca la root del filesystem.

5. Lettura di /etc/passwd. Spostandosi in etc e leggendo il file passwd si ottiene l'elenco completo degli account del sistema, con in cima root e più sotto msfadmin, user e i servizi: la Null Session ha permesso l'accesso a informazioni sensibili senza autenticazione.



Contenuto di /etc/passwd letto sfruttando la Null Session.